

Website Vulnerability Scanner Report (Light)



Unlock the full capabilities of this scanner



See what the DEEP scanner can do

Perform in-depth website scanning and discover high risk vulnerabilities.

Testing areas	Light scan	Deep scan
Website fingerprinting	✓	✓
Version-based vulnerability detection	✓	✓
Common configuration issues	✓	✓
SQL injection	—	✓
Cross-Site Scripting	—	✓
Local/Remote File Inclusion	—	✓
Remote command execution	—	✓
Discovery of sensitive files	—	✓

✓ <https://maharyuda.my.id/login>

! The Light Website Scanner didn't check for critical issues like SQLi, XSS, Command Injection, XXE, etc.
[Upgrade to run Deep scans with 40+ tests](#) and detect more vulnerabilities.

Summary

Overall risk level:

High

Risk ratings:

Critical:	0
High:	2
Medium:	0
Low:	3
Info:	3

Scan information:

Start time:	Jun 09, 2026 / 12:41:56 UTC+03
Finish time:	Jun 09, 2026 / 12:42:26 UTC+03
Scan duration:	30 sec
Tests performed:	41
Scan status:	Finished

Findings

🚩 **Vulnerabilities found for next.js 14.2.35**
port 443/tcp

CVE	CVSS	EPSS Score	EPSS Percentile	Summary
CVE-2026-44578	8.6	0.07215	0.91765	Next.js is a React framework for building full-stack web applications. From 13.4.13 to before 15.5.16 and 16.2.5, self-hosted applications using the built-in Node.js server can be vulnerable to server-side request forgery through crafted WebSocket upgrade requests. An attacker can cause the server to proxy requests to arbitrary internal or external destinations, which may expose internal services or cloud metadata endpoints. Vercel-hosted deployments are not affected. This vulnerability is fixed in 15.5.16 and 16.2.5.

CVE-2026-44573	7.5	0.00052	0.16629	Next.js is a React framework for building full-stack web applications. From 12.2.0 to before 15.5.16 and 16.2.5, Applications using the Pages Router with i18n configured and middleware/proxy-based authorization can allow unauthorized access to protected page data through locale-less <code>/_next/data/<buildId>/<page>.json</code> requests. In affected configurations, middleware does not run for the unprefixed data route, allowing an attacker to retrieve SSR JSON for protected pages without passing the intended authorization checks. This vulnerability is fixed in 15.5.16 and 16.2.5.
CVE-2026-27980	6.9	0.00023	0.06824	Next.js is a React framework for building full-stack web applications. Starting in version 10.0.0 and prior to version 16.1.7, the default Next.js image optimization disk cache (<code>/_next/image</code>) did not have a configurable upper bound, allowing unbounded cache growth. An attacker could generate many unique image-optimization variants and exhaust disk space, causing denial of service. This is fixed in version 16.1.7 by adding an LRU-backed disk cache with <code>images.maximumDiskCacheSize</code> , including eviction of least-recently-used entries when the limit is exceeded. Setting <code>maximumDiskCacheSize: 0</code> disables disk caching. If upgrading is not immediately possible, periodically clean <code>._next/cache/images</code> and/or reduce variant cardinality (e.g., tighten values for <code>images.localPatterns</code> , <code>images.remotePatterns</code> , and <code>images.qualities</code>).
CVE-2026-29057	6.3	0.00031	0.09322	Next.js is a React framework for building full-stack web applications. Starting in version 9.5.0 and prior to versions 15.5.13 and 16.1.7, when Next.js rewrites proxy traffic to an external backend, a crafted <code>DELETE`/`OPTIONS`</code> request using <code>Transfer-Encoding: chunked`</code> could trigger request boundary disagreement between the proxy and backend. This could allow request smuggling through rewritten routes. An attacker could smuggle a second request to unintended backend routes (for example, internal/admin endpoints), bypassing assumptions that only the configured rewrite destination/path is reachable. This does not impact applications hosted on providers that handle rewrites at the CDN level, such as Vercel. The vulnerability originated in an upstream library vendored by Next.js. It is fixed in Next.js 15.5.13 and 16.1.7 by updating that dependency's behavior so <code>content-length: 0`</code> is added only when both <code>content-length`</code> and <code>transfer-encoding`</code> are absent, and <code>transfer-encoding`</code> is no longer removed in that code path. If upgrading is not immediately possible, block chunked <code>DELETE`/`OPTIONS`</code> requests on rewritten routes at the edge/proxy, and/or enforce authentication/authorization on backend routes.
CVE-2026-44580	6.1	0.00012	0.01922	Next.js is a React framework for building full-stack web applications. From 13.0.0 to before 15.5.16 and 16.2.5, applications that use <code>beforeInteractive</code> scripts together with untrusted content can be vulnerable to cross-site scripting. In affected versions, serialized script content was not escaped safely before being embedded into the document, which could allow attacker-controlled input to break out of the intended script context and execute arbitrary JavaScript in a visitor's browser. This vulnerability is fixed in 15.5.16 and 16.2.5.

▼ Details

Risk description:

The risk is that an attacker could search for an appropriate exploit (or create one himself) for any of these vulnerabilities and use it to attack the system.

Since the vulnerabilities were discovered using only version-based testing, the risk level for this finding will not exceed 'high' severity. Critical risks will be assigned to vulnerabilities identified through accurate active testing methods.

Recommendation:

In order to eliminate the risk of these vulnerabilities, we recommend you check the installed software version and upgrade to the latest version.

Classification:

EPSS score : 0.07215

EPSS percentile : 0.91765

CISA KEV: False

CVE : [CVE-2026-44578](#), [CVE-2026-44573](#), [CVE-2026-27980](#), [CVE-2026-29057](#), [CVE-2026-44580](#)

CVSS V3 : 8.6

CWE : [CWE-1035](#)

Vulnerabilities found for nginx 1.21.5

port 443/tcp

CVE	CVSS	EPSS Score	EPSS Percentile	Summary
CVE-2023-44487	7.5	0.944	0.99976	The HTTP/2 protocol allows a denial of service (server resource consumption) because request cancellation can reset many streams quickly, as exploited in the wild in August through October 2023.

CVE-2022-41742	7.1	0.00086	0.24741	NGINX Open Source before versions 1.23.2 and 1.22.1, NGINX Open Source Subscription before versions R2 P1 and R1 P1, and NGINX Plus before versions R27 P1 and R26 P1 have a vulnerability in the module ngx_http_mp4_module that might allow a local attacker to cause a worker process crash, or might result in worker process memory disclosure by using a specially crafted audio or video file. The issue affects only NGINX products that are built with the module ngx_http_mp4_module, when the mp4 directive is used in the configuration file. Further, the attack is possible only if an attacker can trigger processing of a specially crafted audio or video file with the module ngx_http_mp4_module.
CVE-2022-41741	7.0	0.00828	0.74875	NGINX Open Source before versions 1.23.2 and 1.22.1, NGINX Open Source Subscription before versions R2 P1 and R1 P1, and NGINX Plus before versions R27 P1 and R26 P1 have a vulnerability in the module ngx_http_mp4_module that might allow a local attacker to corrupt NGINX worker memory, resulting in its termination or potential other impact using a specially crafted audio or video file. The issue affects only NGINX products that are built with the ngx_http_mp4_module, when the mp4 directive is used in the configuration file. Further, the attack is possible only if an attacker can trigger processing of a specially crafted audio or video file with the module ngx_http_mp4_module.
CVE-2025-23419	5.3	0.02857	0.8652	When multiple server blocks are configured to share the same IP address and port, an attacker can use session resumption to bypass client certificate authentication requirements on these servers. This vulnerability arises when TLS Session Tickets https://nginx.org/en/docs/http/ngx_http_ssl_module.html#ssl_session_ticket_key are used and/or the SSL session cache https://nginx.org/en/docs/http/ngx_http_ssl_module.html#ssl_session_cache are used in the default server and the default server is performing client certificate authentication. Note: Software versions which have reached End of Technical Support (EoTS) are not evaluated.

▼ Details

Risk description:

The risk is that an attacker could search for an appropriate exploit (or create one himself) for any of these vulnerabilities and use it to attack the system.

Since the vulnerabilities were discovered using only version-based testing, the risk level for this finding will not exceed 'high' severity. Critical risks will be assigned to vulnerabilities identified through accurate active testing methods.

Recommendation:

In order to eliminate the risk of these vulnerabilities, we recommend you check the installed software version and upgrade to the latest version.

Classification:

EPSS score : 0.944

EPSS percentile : 0.99976

CISA KEV: False

CVE : [CVE-2023-44487](#), [CVE-2022-41742](#), [CVE-2022-41741](#), [CVE-2025-23419](#)

CVSS V3 : 7.5

CWE : [CWE-1035](#)

🚩 **Unsafe security header: Content-Security-Policy**

CONFIRMED

port 443/tcp

URL	Evidence
https://maharyuda.my.id/login	Response headers include the HTTP Content-Security-Policy security header with the following security issues: <pre>script-src: 'self' can be problematic if you host JSONP, Angular or user uploaded files. script-src: 'unsafe-inline' allows the execution of unsafe in-page scripts and event handlers. script-src: 'unsafe-eval' allows the execution of code injected into DOM APIs such as eval().</pre> Request / Response

▼ Details

Risk description:

For example, if the unsafe-inline directive is present in the CSP header, the execution of inline scripts and event handlers is allowed. This can be exploited by an attacker to execute arbitrary JavaScript code in the context of the vulnerable application.

Recommendation:

Remove the unsafe values from the directives, adopt nonces or hashes for safer inclusion of inline scripts if they are needed, and explicitly define the sources from which scripts, styles, images or other resources can be loaded.

References:

https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy>

Classification:

CWE : [CWE-1021](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

🚩 Password Submitted in URL

port 443/tcp

UNCONFIRMED ⓘ

URL	Method	Parameters	Evidence
https://maharyuda.my.id/login	GET	Headers: User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	The following form sends inputs of type password plainly in the URL: <pre><form class="space-y-5"><input id="email" type="email" placeholder="email" required="" autocomplete="username" maxlength="254" class="w-full h-12 px-5 bg-slate-900/40 border border-slate-600/50 text-white placeholder:text-slate-400 rounded-full focus:outline-none focus:ring-2 focus:ring-blue-500/50" value=""><div class="flex gap-3"><div class="relative flex-1"><input id="password" type="password" placeholder="password" required="" autocomplete="current-password" maxlength="128" class="w-full h-12 px-5 bg-slate-900/40 border border-slate-600/50 text-white placeholder:text-slate-400 rounded-full focus:outline-none focus:ring-2 focus:ring-blue-500/50" value=""><button type="button" class="absolute right-4 top-1/2 -translate-y-1/2 text-slate-400 hover:text-white"><svg xmlns="http://www.w3.org/2000/svg" width="18" height="18" viewBox="0 0 24 24" fill="none" stroke="currentColor" stroke-width="2" stroke-linecap="round" stroke-linejoin="round" class="lucide lucide-eye" aria-hidden="true"><path d="M2.062 12.348a1 1 0 0 1 0-.696 10.75 10.75 0 0 1 19.876 0 1 1 0 0 1 0 .696 10.75 10.75 0 0 1 -19.876 0"></path><circle cx="12" cy="12" r="3"></circle></svg></button></div><button type="submit" class="h-12 w-12 rounded-full bg-primary flex items-center justify-c... (truncated) Request / Response</pre>

▼ Details

Risk description:

Passwords submitted in URLs have a higher chance of being leaked. The main reason is that URLs can be leaked in browser cross-site requests via the Referer header. Additionally, URLs are usually stored in all kinds of logs. If any access or error logs of the server were publicly accessible, an attacker could also harvest password from it.

Recommendation:

You should submit passwords using POST rather than GET. This way sensitive data won't be shared to other locations via URLs.

References:

https://developer.mozilla.org/en-US/docs/Web/Security/Referer_header:_privacy_and_security_concerns

Classification:

CWE : [CWE-598](#)

OWASP Top 10 - 2021 : [A4 - Insecure Design](#)

OWASP Top 10 - 2025 : [A06 - Insecure Design](#)

🚩 Server software and technology found

port 443/tcp

UNCONFIRMED ⓘ

Software / Version	Category
 Lucide	Font scripts
 Next.js 14.2.35	JavaScript frameworks, Web frameworks, Web servers, Static site generator
 Next.js App Router	JavaScript frameworks, Web servers
 Nginx 1.21.5	Web servers, Reverse proxies
 React	JavaScript frameworks
 Webpack	Miscellaneous

 Priority Hints	Performance
 HSTS	Security

▼ Details

Risk description:

The risk is that an attacker could use this information to mount specific attacks against the identified software type and version.

Recommendation:

We recommend you to eliminate the information which permits the identification of software platform, technology, server and operating system: HTTP server headers, HTML meta information, etc.

References:

https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/01-Information_Gathering/02-Fingerprint_Web_Server.html

Classification:

CWE : [CWE-200](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Login Interface Found

port 443/tcp

CONFIRMED

URL	Evidence
https://maharyuda.my.id/login	<pre><input id="email" type="email" placeholder="email" required="" autocomplete="username" maxlength="254" class="w-full h-12 px-5 bg-slate-900/40 border border-slate-600/50 text-white placeholder:text-slate-400 rounded-full focus:outline-none focus:ring-2 focus:ring-blue-500/50" value=""> <input id="password" type="password" placeholder="password" required="" autocomplete="current-password" maxlength="128" class="w-full h-12 px-5 bg-slate-900/40 border border-slate-600/50 text-white placeholder:text-slate-400 rounded-full focus:outline-none focus:ring-2 focus:ring-blue-500/50" value=""> <button type="submit" class="h-12 w-12 rounded-full bg-primary flex items-center justify-center text-primary-foreground hover:opacity-90 shadow-lg disabled:opacity-70"><svg xmlns="http://www.w3.org/2000/svg" width="20" height="20" viewBox="0 0 24 24" fill="none" stroke="currentColor" stroke-width="2" stroke-linecap="round" stroke-linejoin="round" class="lucide lucide-chevron-right" aria-hidden="true"> <path d="m9 18 6-6-6 6"></path></svg></button></pre>
	Request / Response

▼ Details

Risk description:

The risk is that an attacker could use this interface to mount brute force attacks against known passwords and usernames combinations leaked throughout the web.

Recommendation:

Ensure each interface is not bypassable using common knowledge of the application or leaked credentials using occasional password audits.

References:

<https://pentest-tools.com/network-vulnerability-scanning/password-auditor>

<http://capec.mitre.org/data/definitions/16.html>

Classification:

CWE : [CWE-287](#)

OWASP Top 10 - 2025 : [A06 - Insecure Design](#)

Security.txt file is missing

port 443/tcp

CONFIRMED

URL
Missing: https://maharyuda.my.id/.well-known/security.txt

▼ Details

Risk description:

There is no particular risk in not having a security.txt file for your server. However, this file is important because it offers a designated channel for reporting vulnerabilities and security issues.

Recommendation:

We recommend you to implement the security.txt file according to the standard, in order to allow researchers or users report any security issues they find, improving the defensive mechanisms of your server.

References:

<https://securitytxt.org/>

Classification:

CWE : [CWE-1188](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

 HTTP OPTIONS enabled

port 443/tcp

CONFIRMED

URL	Method	Summary
https://maharyuda.my.id/login	OPTIONS	We did a HTTP OPTIONS request. The server responded with a 405 status code and the header: Allow: GET, HEAD Request / Response

Details**Risk description:**

The only risk this might present nowadays is revealing debug HTTP methods that can be used on the server. This can present a danger if any of those methods can lead to sensitive information, like authentication information, secret keys.

Recommendation:

We recommend that you check for unused HTTP methods or even better, disable the OPTIONS method. This can be done using your webserver configuration.

References:

<https://techcommunity.microsoft.com/t5/iis-support-blog/http-options-and-default-page-vulnerabilities/ba-p/1504845>

<https://docs.nginx.com/nginx-management-suite/acm/how-to/policies/allowed-http-methods/>

Classification:

CWE : [CWE-16](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Scan coverage information**List of tests performed (41)****Port 443**

- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for passwords submitted in URLs
- ✓ Scanned for website technologies
- ✓ Scanned for unsafe HTTP header Content Security Policy
- ✓ Scanned for enabled HTTP OPTIONS method
- ✓ Scanned for login interfaces
- ✓ Scanned for absence of the security.txt file
- ✓ Scanned for client access policies
- ✓ Scanned for robots.txt file
- ✓ Scanned for use of untrusted certificates
- ✓ Scanned for enabled HTTP debug methods
- ✓ Scanned for secure communication
- ✓ Scanned for directory listing

- ✔ Scanned for passwords submitted unencrypted
- ✔ Scanned for error messages
- ✔ Scanned for debug messages
- ✔ Scanned for code comments
- ✔ Scanned for missing HTTP header - Strict-Transport-Security
- ✔ Scanned for missing HTTP header - Content Security Policy
- ✔ Scanned for missing HTTP header - X-Content-Type-Options
- ✔ Scanned for missing HTTP header - Referrer
- ✔ Scanned for domain too loose set for cookies
- ✔ Scanned for mixed content between HTTP and HTTPS
- ✔ Scanned for cross domain file inclusion
- ✔ Scanned for internal error code
- ✔ Scanned for HttpOnly flag of cookie
- ✔ Scanned for Secure flag of cookie
- ✔ Scanned for secure password submission
- ✔ Scanned for sensitive data
- ✔ Scanned for OpenAPI files
- ✔ Scanned for file upload
- ✔ Scanned for SQL statement in request parameter
- ✔ Scanned for password returned in later response
- ✔ Scanned for Path Disclosure
- ✔ Scanned for Session Token in URL
- ✔ Scanned for API endpoints
- ✔ Scanned for emails
- ✔ Scanned for missing HTTP header - Rate Limit
- ✔ Scanned for PEM-encoded private key material
- ✔ Scanned for partial PEM-encoded private key material

Scan parameters

target:	https://maharyuda.my.id/login
scan_type:	Light
authentication:	False

Scan stats

Unique Injection Points Detected:	1
URLs spidered:	1
Total number of HTTP requests:	10
Average time until a response was received:	315ms